

C'est quoi un incident de sécurité?

Un incident de sécurité est une occurrence ou un événement qui compromet le bon fonctionnement, la sécurité d'un système d'information ou bien la modification ou la destruction non autorisés d'informations. Autrement dit, c'est tout incident intentionnel ou non intentionnel qui constitue une menace accrue pour la sécurité informatique. Il peut s'agir d'une menace suspectée, tentée, réussie ou imminente de cet accès non autorisé.

Impacts des incidents de sécurité :

- Perte de données.
- Dommages à l'image publique.
- Réduction de la productivité.

Qualification d'un incident de sécurité :

Lorsqu'un incident de sécurité se produit, une des premières étapes du processus de réponse aux incidents consiste à répondre à la question « À quel point est-ce grave ? » ou bien qualifier l'incident. La réponse à cette question est la clé pour bien préciser la stratégie de défense adéquate à chaque situation, en fin de compte, améliorer la sécurité du système informatique.

A quoi sert la qualification d'un incident ?

- Accélérer la prise de décision
- Initier rapidement et efficacement la réponse
- Prioriser la gestion des incidents
- Renforcer le plan de réponse

Les classes de qualification d'un incident de sécurité:

- **Risque majeur** (le plus critique et le plus urgent)
- **Risque modéré**
- **Risque mineur** (le moins critique et le moins urgent)

C'est quoi Kill Chain ?

La cyber **KILL CHAIN** est un modèle de cyber sécurité créé par Lockheed Martin qui retrace les étapes d'une cyberattaque, identifie les vulnérabilités et aide les équipes de sécurité à stopper les attaques à chaque étape de la chaîne.

Il consiste en l'identification d'une cible, l'envoi, la décision, l'ordre et enfin la destruction de la cible.

Les étapes de la Kill Chain ?

1. **RECONNAISSANCE** : le cyber attaquant sélectionne la cible, collecte les informations et tente d'identifier les vulnérabilités du réseau cible.
2. **ARMEMENT** : le cyber attaquant crée une arme, moyen (des logiciels malveillants ou malwares sont utilisés) pour infiltrer le SI de la cible.
3. **LIVRAISON** : l'attaquant transmet l'arme à la cible (via PJ par mail, site web ou clé USB).
4. **EXPLOITATION** : Exploiter une vulnérabilité afin d'accéder au système d'information de la victime, plusieurs moyens peuvent être utilisés (faille 0 Day les vulnérabilités, l'ouverture d'une pièce jointe ou le fait de cliquer sur un lien malveillant) :
5. **INSTALLATION** : le logiciel malveillant installe un point d'accès (une porte dérobée) utilisable par un attaquant externe.
6. **COMMANDE & CONTRÔLE** : Le logiciel malveillant installé précédemment ouvre un canal de communication vers le pirate informatique. Ce logiciel est à l'entrée, prêt à exécuter les commandes du pirate.
7. **ATTAQUE** : L'attaquant extrait finalement les données du système. L'objectif consiste à collecter, crypter et extraire des informations confidentielles de l'environnement de l'organisation.

Norme ISO 27035:2011 ?

C'est une approche pour évaluer et améliorer la réponse aux incidents de sécurité.

A quoi consiste l'ISO 27035 :2011 ?

1. Détecter, signaler et évaluer les incidents de sécurité de l'information.
2. Répondre aux incidents de sécurité de l'information et les gérer.

3. Détecter, évaluer et gérer les vulnérabilités de la sécurité de l'information.
4. Améliorer en permanence la sécurité de l'information et la gestion des incidents grâce à la gestion des incidents et des vulnérabilités de la sécurité de l'information.

Les étape 27035 :2011 ?

1. **Planification** : l'organisation se prépare à détecter, gérer et récupérer des attaques et autres incidents. Il se concentre sur la documentation de la politique de signalement et de traitement des événements et des incidents de sécurité de l'information. (Posez les questions QUI / QUAND).
2. **Détection** : l'identification de l'incident et le niveau de réponse approprié.
3. **Evaluation** : vise à identifier positivement un incident, déterminer la gravité de l'incident.
4. **Répondre** : identifier les réponses supplémentaires nécessaires pour ramener le système à un fonctionnement normal.
5. **Apprentissage** : ce qui a conduit à l'incident, ce qui s'est passé, comment ce dernier a été géré, et de comprendre comment il s'est produit en analysant les obstacles Enfin proposer les améliorations à l'aide d'une analyse après l'incident.

C'est quoi le 800-61 R2 du NIST ? ou NIST ?

Le guide de traitement des incidents de cybersécurité du NIST vise à aider les organisations, à améliorer leur posture de sécurité et leurs capacités de réponse aux incidents grâce à une planification, une formation à la cybersécurité et une allocation de ressources appropriées

NIST: National Institute of Standards and Technology.

Les 4 phases du processus NIST (800-61 R2) ?

1. **Préparation**: minimiser les impacts des incidents de sécurité et à maintenir la continuité des activités. La Proactivité dans cette phase doit être élevée pour s'assurer que les événements imprévus.
2. **Détection et analyse des incidents**: détecter et d'analyser rapidement une occurrence d'incident. Il commence dès qu'un événement suspect ou inhabituel est détecté et signalé.
3. **Réponse aux incidents** : consiste à identifier les actions d'intervention immédiate pour Faire face à l'incident de sécurité de l'information.
4. **Activité post-incident** : Cette phase a lieu une fois que l'incident de sécurité de l'information a été résolu ou clôturé. Compiler un résumé des actions et des résultats

Les actions qui doivent être faite sur la phase réponse au incidents :

1- Les étapes de la Confinement initial de l'incident:

- ✓ Acquérir, conserver, sécuriser et documenter les preuves
- ✓ Confirmer le confinement de l'incident
- ✓ Analyser davantage l'incident et déterminer si le confinement a réussi
- ✓ Mettre en œuvre des mesures de confinement supplémentaires, si nécessaire

2- Éradiquer l'incident:

- ✓ Identifier et atténuer toutes les vulnérabilités qui ont été exploitées
- ✓ Le gestionnaire d'incidents peut se charger des activités nécessaires pour résoudre le problème et restaurera les services concernés à leur état normal.
- ✓ Supprimer les composants des systèmes à l'origine de l'incident

3- Récupérer de l'incident :

- ✓ Remettre les systèmes et services concernés dans un état prêt à fonctionner
- ✓ Confirmer que les systèmes et services concernés fonctionnent normalement

Définir les menaces persistantes avancées (APT - Advanced Persistent Threat) :

Une cyberattaque dans laquelle les pirates travaillent ensemble en utilisant des méthodes et outils sophistiquées et avancées pour infiltrer des systèmes et y rester souvent inaperçus pendant une longue période. Un groupe d'attaquants avancés qui sont bien financés par une organisation ou un gouvernement pour obtenir des informations cruciales sur leur organisation cible ou gouvernement

Caractéristiques de menaces persistantes avancées (APT) ?

- Plus dangereux.
- Cibles précises.
- Objectifs clairs.
- Techniques d'attaque furtives.
- Attaque complexe:
- Attaquants bien organisés.
- Tentatives répétées.

Threat Hunting :

Stratégie proactive conçue pour trouver des menaces inconnues ou des adversaires cachés à l'intérieur d'un réseau avant qu'ils ne puissent exécuter une attaque ou atteindre leurs objectifs.

Méthodologies du Threat Hunting :

- 1- Chasse par hypothèses
- 2- Chasse structurée
- 3- Chasse non structurée

Identification des étapes du processus Threat Hunting :

Étape 1 : Déclencheur.

Étape 2 : Enquête.

Étape 3 : Résolution.

Place du Threat Hunting dans la stratégie de sécurité ?

Le Threat Hunting est considéré comme un complément essentiel pour renforcer la sécurité d'un système. Il peut être implémenté en parallèle avec la stratégie de défense ordinaire d'une entreprise.

Définition d'un plan de réponse aux incidents :

Identifie et décrit les objectifs, les attentes, les rôles et les responsabilités en ce qui concerne la préparation, la détection, l'activation/la réponse, le confinement, la correction des notifications, la résolution et l'analyse après action des incidents de sécurité de l'information.

Objectifs d'un plan de réponse aux incidents ?

- Fournir une stratégie de réponse cohérente aux menaces de sécurité de l'information qui mettent en danger les données et les systèmes universitaires.
- Protéger la confidentialité, l'intégrité et la disponibilité des systèmes, réseaux et données universitaires.
- Protéger le bien-être de la communauté universitaire et minimiser les atteintes à la réputation.
- Aider l'université à se rétablir après des incidents de sécurité de l'information.
- Mettre en œuvre des actions correctives opportunes et appropriées.
- Répondre aux exigences légales ou réglementaires.

Pourquoi la planification de la réponse aux incidents est-elle importante?

- Fournit un processus standard pour la réponse aux incidents.
- Aide à répondre rapidement et efficacement
- Prépare les équipes pour les scénarios clés
- Protège les informations sensibles

Comment créer un plan de réponse aux incidents ?

- Un plan de réponse aux incidents doit être mis en place pour traiter une violation de données suspectée en une série de phases. Dans chaque phase, il y a des domaines spécifiques de besoins qui doivent être pris en compte.
- Plusieurs étapes sont nécessaires pour atténuer complètement l'incident, tout en empêchant la destruction des preuves qui pourraient être nécessaires aux poursuites.

6 étapes de réponse aux incidents ?

Préparation : Les plans de réponse aux incidents mettent l'accent sur la phase de préparation car c'est le point de départ pour déterminer les outils et les ressources nécessaires pour bien réagir contre les incidents. Ainsi, elle permet de prévenir les incidents en s'assurant que les systèmes.

Identification : s'effectue grâce à la surveillance des réseaux et systèmes informatiques et la détection du moindre écart par rapport aux activités normales.

Endiguement : l'application d'un confinement à court terme (Isolant le segment).

Éradication : vise à trouver et éliminer la cause profonde de l'incident par la suppression des logiciels malveillants introduits par les attaques puis la restauration de tous les systèmes affectés.

Récupération : restaurer et remettre tous les systèmes et appareils en état de fonctionnement complet, après avoir vérifié qu'ils sont propres et que la menace a été complètement supprimée.

Leçons apprises : tâche pour renforcer la sécurité du système.

Les tâches primordiales de la phase "préparation" ?

- Définir les incidents de sécurité critiques sur lesquels l'équipe doit se concentrer.
- Examiner et codifier une politique de sécurité organisationnelle.
- Effectuer une évaluation des risques.

Les tâches primordiales de la phase "éradication" ?

- Suppression des logiciels malveillants de tous les systèmes affectés.
- Identification de la cause première de l'attaque.
- Définition des règles pour empêcher des attaques similaires à l'avenir.

Les implications de la procédure de récupération?

- Définition de l'heure et la date des opérations de restauration
- Vérification que les systèmes sont propres et entièrement fonctionnels au fur et à mesure de leur mise en service
- Surveillance continue pendant un certain temps après l'incident pour observer les opérations et vérifier les comportements anormaux.

Les principales tâches à faire lors de l'étape « Leçon apprises » ?

- Faire une analyse complète de l'incident et ses dégâts.
- Documenter tout ce qui concerne l'incident.
- Déterminez ce qui a bien fonctionné dans le plan de réponse.
- Extraire les leçons qui peuvent aider à améliorer le plan de réponse pour les prochains à l'incident.

Qu'est-ce qu'une réponse automatisée aux incidents ?

La gestion automatisée des incidents est le processus d'automatisation de la réponse aux incidents pour garantir que les incidents critiques sont détectés et traités de la manière la plus efficace et la plus cohérente.

Quelle est l'importance de la réponse automatisée aux incidents ?

- La rapidité, L'automatisation accélère les réponses et les tâches de routine réduisant considérablement le temps de réponse face à une cyber menace.
- L'automatisation permet de minimiser l'intervention humaine autant que possible.
- Un accélérateur pour atteindre l'objectif de répondre intelligemment en un temps record.

Les étapes de l'automatisation des réponses aux incidents :

- 1- Créer le plan de réponse convenable au réseau à sécuriser.
- 2- Identifier et classer les incidents.
- 3- Automatiser les actions de réponses aux incidents.
- 4- Évaluer et affiner continuellement le processus d'automatisation.
- 5- Développer des modèles de réponses automatisées matures.

Les critères pour mieux choisir les technologies d'automatisation :

- Il est important de déterminer la partie du processus qui doit être automatisée. Bien qu'il existe plusieurs outils d'automatisée.
- S'assurer que l'équipe de sécurité possède les compétences nécessaires pour utiliser ces outils efficacement le plus rapidement possible.

Analyse et déclaration:

- Évaluer l'événement et confirmer qu'il s'agit d'un incident ;
- Désigner les personnes responsables de l'incident ;
- Déterminer le type de l'incident ;
- Déterminer le vecteur d'attaque susceptible ;
- Déterminer les données, systèmes ou réseaux touchés ;

- Cerner l'impact sur la confidentialité, l'intégrité et la disponibilité ;
- Aviser les personnes compétentes.

Liste des d'outils de réponse aux incidents gratuits:

AlienVault : Il permet de faire l'évaluation des vulnérabilités, la détection des intrusions basée sur les données d'événements, l'analyse comportementale et les règles de corrélation des événements.

GRR Rapid Response: est un framework de réponse aux incidents axé sur la criminalistique en direct à distance.

Velociraptor: est une plateforme open-source avancée de surveillance des terminaux, de criminalistique numérique. C'est un outil qui permet de collecter des informations d'état basées sur l'hôte à l'aide des requêtes Velociraptor Query Language (VQL).

TheHive: est d'un système de management du centre des opérations de sécurité (qui permet aux équipes de collaborer pour effectuer des recherches de qualité, et enquêter sur les incidents de sécurité de qualité et en temps opportun.

SANS Investigative Forensic Toolkit (SIFT) : Il fournit des fonctionnalités telles que la création d'une chronologie à partir des journaux système, la sculpture de fichiers pour extraire des preuves spécifiques et l'analyse de la corbeille.

SolarWinds: Bien qu'il soit appelé Security Event Manager (SEM), cet outil est un Security Information Manager (SIM). Il recherche dans les fichiers journaux pour identifier une éventuelle activité malveillante.

Splunk Phantom : est un système d'Orchestration, d'automatisation et de réponse aux incidents (SOAR). Il fait partie d'une plate-forme plus large appelée Splunk.

LogRhythm NextGen SIEM : est une Platform qui fournit des services pour détecter et arrêter les menaces de sécurité.

Définition :

Un incident de sécurité :

Un incident de sécurité est une occurrence ou un événement qui compromet le bon fonctionnement, la sécurité d'un système d'information ou bien la modification ou la destruction non autorisés d'informations.

Vulnérabilité :

Faiblesse au niveau d'un bien (au niveau de la conception, de la réalisation, de l'installation, de la configuration ou de l'utilisation du bien).

Menace :

Cause potentielle d'un incident, qui pourrait entraîner des dommages sur un bien si cette menace se concrétisait.

Attaque

Action malveillante destinée à porter atteinte à la sécurité d'un bien. Une attaque représente la **concrétisation d'une menace**, et nécessite **l'exploitation d'une vulnérabilité**.

Cryptographie :

Mécanisme permettant d'implémenter du chiffrement et des signatures électroniques

Pare-feu:

Équipement permettant d'isoler des zones réseaux entre-elles et de n'autoriser le passage que de certains flux seulement

Contrôles d'accès logiques :

Mécanismes permettant de restreindre l'accès en lecture/écriture/suppression aux ressources aux seules personnes dûment habilitées

Sécurité physique des équipements et locaux :

Mécanismes de protection destinés à protéger l'intégrité physique du matériel et des bâtiments/bureaux.

Anti-virus:

Mécanisme technique permettant de détecter toute attaque virale qui a déjà été identifiée par la communauté sécurité.

CERT: Computer Emergency Response Team

C'est un groupe d'experts en sécurité de l'information responsable de la protection, de la détection et de la réponse aux incidents de cybersécurité d'une organisation.

SOC : security Operation Center :

Le SOC est une plateforme permettant la supervision et l'administration de la sécurité du système d'information au travers d'outils de collecte.

IOC : Indicator of compromise :

Les indicateurs de compromission (IOC) servent de preuves médico-légales d'intrusions potentielles sur un système ou un réseau hôte. Ces artefacts permettent aux professionnels de la sécurité de l'information (InfoSec) et aux administrateurs système de détecter les tentatives d'intrusion ou d'autres activités malveillantes.

XSS: Cross Site Scripting:

C'est une attaque de type d'injection, dans lequel des scripts malveillants sont injectés dans des sites Web autrement bénins et fiables. Les attaques XSS se produisent lorsqu'un attaquant utilise une application Web pour envoyer un code malveillant, généralement sous la forme d'un script côté navigateur, à un autre utilisateur final.

IDS : Intrusion Detection System :

C'est un système de surveillance qui détecte les activités suspectes et génère des alertes lorsqu'elles sont détectées. Sur la base de ces alertes, un analyste du centre des opérations de sécurité (SOC) ou un intervenant en cas d'incident peut enquêter sur le problème et prendre les mesures appropriées pour remédier à la menace.

SIEM: Security Information and Event Management:

Les organisations à détecter, analyser et réagir aux menaces liées à la sécurité avant qu'elles ne nuisent à leur activité professionnelle.

OSINT : Open-source intelligence:

C'est la collecte et l'analyse de données recueillies à partir de sources ouvertes pour produire des renseignements exploitables.

NIST: National Institute of Standards and Technology:

Forensics:

Également connue sous le nom de criminalistique, est l'application de la science aux lois pénales et civiles, principalement - du côté pénal - lors d'enquêtes pénales, telles que régies par les normes juridiques de la preuve admissible et de la procédure pénale.

ISO 27001 :

C'est une norme de sécurité de l'information créée par l'Organisation internationale de normalisation (ISO), qui fournit un cadre et des lignes directrices pour l'établissement, la mise en œuvre et la gestion d'un système de gestion de la sécurité de l'information (ISMS).

ISO 27002

Standard est un ensemble de directives de sécurité de l'information destinées à aider une organisation à mettre en œuvre, à maintenir et à améliorer sa gestion de la sécurité de l'information.

ISO 27004 :

Propose des lignes directrices sur la façon de déterminer les performances d'ISO 27001. Il décrit comment créer et exploiter des systèmes d'évaluation et comment analyser et divulguer les effets d'un ensemble de mesures de sécurité de l'information.

ISO 27005 :

C'est une norme internationale qui décrit les procédures d'évaluation des risques de sécurité de l'information conformément à la norme ISO 27001. Comme indiqué précédemment, les évaluations des risques sont un élément essentiel de l'initiative de conformité à la norme ISO 27001 d'une organisation.

ISO 27035 :

C'est une norme internationale qui fournit les meilleures pratiques et lignes directrices pour la réalisation d'un plan stratégique de gestion des incidents et la préparation d'une intervention en cas d'incident.

ISO 27037 :

fournit des lignes directrices pour des activités spécifiques dans le traitement des preuves numériques, qui sont l'identification, la collecte, l'acquisition et la préservation des preuves numériques potentielles qui peuvent avoir une valeur probante.